

4EYES FORENSICS

Two pairs of eyes · one verdict

Penetration testing engagement: scoping questionnaire

Document version	1.3	Template owner	4Eyes Forensics
Engagement reference	4EF-SCOPE-_____ (issued by 4Eyes; leave blank if not supplied)	Date issued to you	
Completed by (name)		Date completed	

Version 1.3 supersedes all earlier issues. If you were sent an earlier version, please complete this one instead.

How to use this document

This questionnaire lets our engineers scope your engagement and return a fixed quote within one business day, usually without a discovery call. Complete the sections that apply to the assessment types you select in Section 2; skip the rest. Where you are unsure, write “TBC” rather than guessing; we will resolve it with your technical contact.

Every engagement is run under the four-eyes principle: two operators on the work, and no finding reported until a second operator has verified it. The scope you define here becomes the authorized scope in the Rules of Engagement we both sign before any testing begins. Every penetration test includes a free retest of remediated findings.

Marking your selections: the boxes and shaded fields in this form are interactive. Open it in Adobe Acrobat Reader, Preview, or any modern PDF reader, click each box that applies and type directly into the fields. Save before returning it. If you would rather print it and complete it by hand, that is equally acceptable.

Return this document encrypted. A completed scope document identifies your attack surface and must never cross an unencrypted mailbox. Choose whichever route below suits your environment; all three are acceptable to us. If you are unsure, call the number at the foot of this page and we will set it up with you in five minutes.

Return route	How it works
☐ Encrypted email session (simplest)	We send you a password-protected message; you reply to it with the completed form attached. Nothing leaves either mailbox in clear text and you need no software or account. We give you the password by phone.
☐ One-time encrypted upload link	Ask us for a single-use upload link, issued against your engagement reference and set to expire. Password given by phone. Suits organizations whose IT policy blocks external mail attachments.
☐ OpenPGP	Encrypt to the key published at https://4eyesforensics.com/.well-known/security.txt and send to secure@4eyesforensics.com . Verify the fingerprint against that page, or by phone, before first use. Do not rely on a fingerprint quoted in any document, including this one.

If none of the above is available to you, an AES-256 encrypted archive (7-Zip or equivalent) emailed to secure@4eyesforensics.com is acceptable, provided the passphrase reaches us by telephone and not by email or text message. Please do not return this form through a web form, file-sharing site or unencrypted attachment.

1. Organization, contacts and agreements

Organization legal name	
Trading name (if different)	

Registered address	
Company registration no.	
Industry / sector	
Approx. headcount	

Agreements in place

An NDA should be in place before you send us your asset inventory. If one is not, tell us and we will issue our standard mutual NDA the same day.

Agreement	Status / reference
☐ Mutual NDA already executed with 4Eyes	Date and reference:
☐ NDA required before we proceed	
☐ Your own NDA or MSA template must be used	Attach or name it:
☐ Existing MSA or framework agreement in place	Reference:

Contacts

The emergency contact must be reachable during all agreed testing windows, including out-of-hours work. We phone before writing when a critical finding is confirmed.

Role	Name	Title	Email	Phone (incl. out of hours)
Primary business contact				
Technical contact				
Emergency / escalation contact				
Authorizing signatory				

The authorizing signatory must have authority to permit testing of the assets in scope, and signs Section 15.

2. Assessment types requested

Click all that apply. Each selected type has a corresponding scope section below.

Assessment type	Complete
☐ External infrastructure penetration test: internet-facing hosts, run by hand, not by scanner	Section 4
☐ Web application penetration test: access control and tenancy boundaries prioritized	Section 5
☐ API penetration test: authenticated and unauthenticated	Section 5
☐ Mobile application penetration test: iOS / Android, client-side and backend	Section 5
☐ Internal infrastructure penetration test: on-site or via provided access	Section 6
☐ Cloud configuration and IAM review: AWS / Azure / GCP, Kubernetes, CI/CD	Section 6
☐ Source code review: targeted or monorepo	Section 6

Assessment type	Complete
☐ PCI DSS segmentation testing: cardholder data environment isolation	Sections 6 and 13
☐ Remote / hybrid workforce assessment: home and field devices	Section 7
☐ OT / ICS assessment: PLCs, SCADA, pump and pressure stations, substations	Section 8
☐ Embedded / IoT assessment: firmware, authentication chips, encrypted comms, bench teardown	Section 8
☐ Red team engagement: objective-led adversary emulation, ends in a purple debrief	Section 9
☐ Phishing simulation / social engineering: under agreed rules	Section 9

3. Drivers, history and data sensitivity

Why is this engagement happening now? Mark all that apply.

☐ Annual or scheduled security testing	
☐ Compliance or audit requirement (state framework in Section 13)	
☐ Customer or contractual requirement	
☐ Cyber insurance requirement	
☐ Recent incident or near-miss (our DFIR team may be relevant; note below)	
☐ New system, major release or migration going live	
☐ Merger, acquisition or due diligence	
☐ Board or executive assurance	

Previous testing

Date of most recent penetration test	
Carried out by (or: first test)	
Can the previous report be shared with us? (Yes / No)	
Were previous findings remediated? (all / partially / no)	
Known issues you already expect us to find	

Data held by in-scope systems

This determines our handling obligations and where we test with additional care. Mark all that apply.

☐ Cardholder data (PAN, CVV) or a cardholder data environment	
☐ Health or patient data	
☐ Special category personal data (biometric, genetic, political, religious, sexual)	
☐ Children's data	

☐ Financial account or transaction data	
☐ Government, defence or otherwise classified material	
☐ Live customer personal data present in the environment we will test	
☐ None of the above; test data only	

What would make this engagement a success, and what are you most worried about?

Your answer	
--------------------	--

4. External infrastructure scope

List everything you consider in scope. We will independently map the internet-facing estate during recon (the real attack surface, not the asset register) and confirm any discovered assets with you before testing them.

IP addresses / CIDR ranges in scope	
Domains and subdomains in scope	
Explicitly OUT of scope (IPs, domains, hosts)	
Approx. number of live external hosts (if known)	
May we test discovered subdomains not listed above, after confirmation? (Yes / No)	
Any assets hosted by third parties (name the provider; see Section 10)	

5. Web, API and mobile application scope

One row per application or API. Continue on an attached sheet if needed.

Application / API name	URL(s) / base endpoint	Environment (prod / staging / UAT)	Auth method and no. of user roles	Multi-tenant? (Y/N)	Approx. size (pages / endpoints)

Application access and protection

WAF, CDN or bot protection in front of these applications? Name the product	
Should we test through the protection (realistic), from an allowlisted source (thorough), or both?	

Will you allowlist our source IP ranges? We supply them at kick-off (Yes / No)	
Rate limiting or lockout policies we should know about	
API documentation available? (OpenAPI / Swagger / Postman; requested at kick-off)	
Test accounts: can you provision at least two per role? (Yes / No)	
Single sign-on or MFA in front of the app? Can it be accommodated for test accounts?	
Areas requiring particular care (payment flows, live customer data, email-sending features)	
Is testing against production acceptable, or staging only?	

Mobile applications

App name	Platform(s)	Distribution (store / enterprise / internal)	Backend APIs listed above? (Y/N)	Approx. size / key features
Can you provide the binaries directly? (IPA / APK / AAB; preferred over store download)				
Debug or non-obfuscated builds available for client-side review? (Yes / No)				
Jailbreak / root detection or certificate pinning present? May we bypass it in test builds?				
MDM or enterprise device constraints on test devices				
Third-party SDKs of concern (payments, analytics, auth)				

6. Internal infrastructure, cloud and source code scope

Sizing

These figures drive the quote more than any other answer in this document. Approximate is fine; "TBC" is better than a guess.

Approx. number of live internal hosts (servers and endpoints)	
Approx. endpoint / workstation count	
Number of physical sites in scope	
Number of internal subnets or VLANs in scope	
Internal networks / VLANs / sites in scope (list)	

Explicitly OUT of scope internally	
------------------------------------	--

Identity and directory

Active Directory: number of forests and domains	
Entra ID / Azure AD, on-premises only, or hybrid?	
Other identity providers in use (Okta, Ping, Google)	
Privileged access tiering in place? (Yes / No / partial)	
Will we be given a standard domain user account as a starting position? (Yes / No)	

Access and logistics

Access method for internal testing (on-site, shipped device, VPN, VDI)	
Site addresses for on-site work	
Site induction, escort or permit-to-work requirements	
Lead time needed for site access or visitor passes	
Any restrictions on equipment we may bring on site	

Cloud, containers and code

Cloud platforms and account / subscription / project IDs in scope	
Approx. number of accounts, subscriptions or projects	
Kubernetes clusters and CI/CD systems in scope	
Read-only auditor credentials available for cloud review? (Yes / No)	
Source code: repositories, approximate size (LOC), languages	
PCI segmentation testing only: describe the CDE boundary and the controls asserted to isolate it	

7. Remote and hybrid workforce scope

Assessment of the devices and access paths your people use away from the office. Complete only if selected in Section 2.

Number of remote or hybrid staff in scope	
Device types and operating systems (corporate laptops, BYOD, mobile, field kit)	

Are devices centrally managed? Name the MDM or endpoint management platform	
Remote access method (VPN, ZTNA, VDI, direct SaaS)	
Endpoint protection product in use	
Sample size: how many devices may we assess, and how will they reach us?	
Are staff to be notified that their device is being assessed? (Yes / No)	

8. OT / ICS and embedded / IoT scope

OT and embedded work is quoted separately and is always agreed hands-on with your engineers. Safety systems are never tested without a written, site-specific method statement.

Sites or plants in scope and locations	
Systems (PLC models, SCADA / HMI platforms, protocols)	
Can testing be performed in a maintenance window or on a test rig? Detail:	
Safety-instrumented systems present? (must be identified)	
Site induction, escort, permit-to-work and PPE requirements	
Devices for bench teardown: what can be shipped to our lab, and how many units?	
Firmware, schematics or debug access available? (JTAG, UART, vendor documentation)	

9. Red team, phishing and physical scope

Objectives (for example: reach crown-jewel system X, exfiltrate a marked test file, obtain domain admin)	
Who is aware of the engagement? (trusted agents list)	
In-scope techniques: phishing, vishing, physical entry, malicious USB, password spraying, C2 on endpoints	
Explicitly prohibited techniques or pretexts	
Deconfliction word or protocol if an operator is challenged	

Phishing and social engineering

Staff population in scope (count and departments)	
---	--

Exclusions (for example clinical, safety-critical or vulnerable staff)	
Email platform (Microsoft 365, Google Workspace, other)	
Will you allowlist our sending domain and infrastructure, or do you want a fully cold run?	
Are pretexts impersonating your brand or named staff permitted?	
Is credential capture in scope, or click-tracking only?	

Physical entry

Authority to test a building is not authority to test other tenants. List each site and confirm who occupies it.

Site address	Legal entity occupying the site	Shared or multi-tenant? (Y/N)	Authority to permit entry testing held? (Y/N)

10. Hosting and third-party authorization

You must have the authority to permit testing of every asset in scope. Where infrastructure is owned or operated by a third party (hosting provider, MSP, SaaS vendor), their consent may be required before we begin.

Provider or third party	What they host or operate	Authorization obtained? (Y / N / in progress)

11. Detection, monitoring and notification

An unnotified monitoring provider may treat our testing as a live intrusion, invoke incident response, bill you for it, and block our source addresses part-way through the window. Please answer this section even for routine testing.

Is security monitoring in-house, outsourced, or both?	
Name of MSSP or SOC provider, if outsourced	
Should the provider be notified before testing begins? (Yes / No / we will handle it)	
Contact at the monitoring provider for deconfliction	
Is blocking of our source addresses expected, or will we be allowlisted?	

Do you want detection performance assessed as part of this engagement? (Yes / No)	
---	--

12. Testing windows and constraints

Preferred start date and any hard deadline (audit date, go-live)	
Permitted testing hours (business hours, out of hours, 24x7)	
Blackout dates or change freezes	
Fragile or availability-critical systems needing gentler treatment	
Denial-of-service testing: excluded by default. Include limited, agreed DoS? (Yes / No)	
Notification preference: advise before exploitation of critical findings? (we phone before writing by default)	
Stop conditions: events that must pause testing immediately	

13. Compliance context, reporting and delivery

Framework or requirement	Detail (audit date, certifying body)
☐ ISO 27001	
☐ SOC 2 (Type I / II)	
☐ Cyber Essentials / Cyber Essentials Plus	
☐ PCI DSS (state level and QSA if known)	
☐ GDPR Article 32	
☐ NIS2 / DORA	
☐ Sector-specific (state)	

Deliverables

Every engagement delivers: an executive brief a board can read; a full technical report with reproduction steps, evidence, CVSS reasoning and a named fix owner; a findings register (CSV or XLSX) that drops into your tracker; a free retest of remediated findings; and, where relevant, regression tests written with your team and a compliance mapping to the frameworks above. Ask for the redacted sample pack if you want to judge the format before signing.

Report recipients (names, roles)	
Readout or debrief required? (executive, technical, or both)	
Preferred retest window after remediation	
Compliance evidence pack required? (Yes / No)	

Secure delivery of your report

Your report is more sensitive than this questionnaire: it lists confirmed, exploitable weaknesses. Tell us how you want it delivered.

Delivery route	Detail
☐ Encrypted email session to the named recipients	Recipients confirmed above
☐ One-time encrypted download link, expiring	Expiry preference:
☐ OpenPGP, encrypted to your key	Supply your public key or fingerprint source:
☐ Your own secure portal or data room	Name it and confirm we will be granted access:
Retention: how long should we retain your report and evidence? (our default is 12 months, then secure destruction)	
Certificate of destruction required at the end of retention? (Yes / No)	

14. What happens next

Once you return this form:

Step	What we do
1. Acknowledgement, same business day	We confirm safe receipt and tell you who is handling your enquiry.
2. Clarification, if needed	If anything is ambiguous we call your technical contact. Most enquiries need no call at all.
3. Fixed quote, within one business day	Scope, effort, dates and price. Fixed, not an estimate that moves later.
4. Rules of Engagement	We issue the RoE: authorized scope, stop conditions, contacts and authorizations. Both parties sign before anything begins.
5. Kick-off	Credentials, allowlisting, site access and final confirmation of the testing window.
6. Testing, then report, then free retest	Critical findings are phoned through as they are confirmed, not held until the report.

15. Authorization

By signing, the authorizing signatory confirms that: (a) the organization owns, or has obtained written authority to test, every asset listed in this document; (b) the information provided is accurate to the best of their knowledge; (c) they are authorized to commit the organization to the engagement. The signed Rules of Engagement (scope, stop conditions and authorizations) will be executed by both parties before any testing activity begins.

Signatory name	
Title	
Signature	
Date	